CRA Incident Simulation

Ad Soyad: Şevval Öcal | Grup / Şube: İÖ 4. Sınıf | Tarih: 06.11.2026

Senaryo: Saat 10:15. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey zaman ve kanıttır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

Cevap: Aranacaklar: OT Siber Güvenlik Lideri ve Fabrika Bakım Müdürü. İlk 3 eylem: 1) Yetkisiz servis hesabının aktif oturumunu derhal sonlandırıp hesabı dondurmak. 2) Ağ kablosunu/VPN tünelini fiziken izole etmek. 3) Hızlıca canlı RAM ve ağ paket izlerini (pcap) bozmadan kaydetmek.

2 İlk 2 saat: Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

Cevap: Emniyet Durumu: Safety PLC bağımsız hattı kontrol edilerek STO ve Acil Duruş fonksiyonlarının aktif olduğu doğrulanır. Korunan Kanıt: PLC bayrak hafızası, Syslog kayıtları ve firewall bağlantı dökümleri imzalanarak korunur. Kapatılan Hesap: İhlale uğrayan servis hesabı ve tüm ilişkili varsayılan bakıcı yetkileri kapatılır.

3 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

Cevap: CRA Erken Uyarı Bilgileri: Olayın tespit zamanı (10:15), ihlal edilen servis hesabı, etkilenen Yektamak dolum hattı bileşenleri, zafiyetin kötüye kullanım şüphesi (PLC konfigürasyon kurcalaması) ve alınan ilk izolasyon önlemlerini içeren resmi bildirim özeti hazır olmalıdır.

4 72 saat — CRA bildirimi: Kök neden, etki, önlem — kim ne yapıyor?

Cevap: Kök Neden: Servis hesabında zayıf kimlik doğrulama/VPN açığı. Etki: Dolum hattı parametre değiştirme riski (fiziksel zarar oluşmadan engellendi). Önlem: OT Ağ Yöneticisi MFA zorunluluğu getirir, Emniyet Mühendisi Safety PLC CRC doğrulaması yapar, Adli Bilişim Uzmanı kök analiz raporunu sunar.

5 14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

Cevap: Korunacak Kayıtlar: İhlal öncesi ve sonrası 30 günlük Firewall trafik logları, PLC proje checksum (CRC) geçmişi, Jump Server video/oturum kayıtları, SCADA alarm dökümleri ve yetkili müdahale zaman çizelgesi tutanakları adli dijital imzeyle arşivlenmiş olmalıdır.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı Incident Workflow → Evidence Pack EP 13 Incident Response başlığına oturur.